CIAM/Auth0: Selected Model 4, Brand + Region Credentials and Current POC Architecture

Decision: the active POC uses **Model 4 : one credential per brand within a region**. DeWalt France and DeWalt Germany use the same DeWalt EU email/password and canonical customer. Stanley requires its own brand registration and credential. UK is a separate regional identity boundary.

Documented: Oct 2, 2026 . **Scope:** the five existing Vercel POC storefronts, EU/EMEA and UK temporary Auth0 tenants. This page records the selected POC model and deployed implementation following the September 30 standup and subsequent testing.

The four-model comparison records the options explored and the earlier demo. Use this page for the current model, tenant mapping and test expectations.

1. Selected model and customer rules

Boundary	Current behavior
Same brand + same region	One email/password credential and canonical customer across participating markets. DeWalt FR ↔ DE is the live demonstration.
Different brand + same region	Explicit signup for the second brand, its own password lifecycle, and ownership proof before linking its identity to the existing regional customer.
Same email + different region	Separate regional customers, enrollment and credentials. EU registration does not authorize UK access.
Customer profile	Owned brand, email-code and Google identities can resolve to one canonical Auth0 account within the same tenant. The original primary subject is preserved during authorized linking.
Browser session	Each storefront has its own local application session. Reusing a credential across FR/DE does not imply automatic cross-domain login.

Why this model: it matches the requested brand/region behavior while keeping a customer's enrolled brands associated with one regional profile. A brand credential is independent; changing or recovering it affects that brand throughout the region.

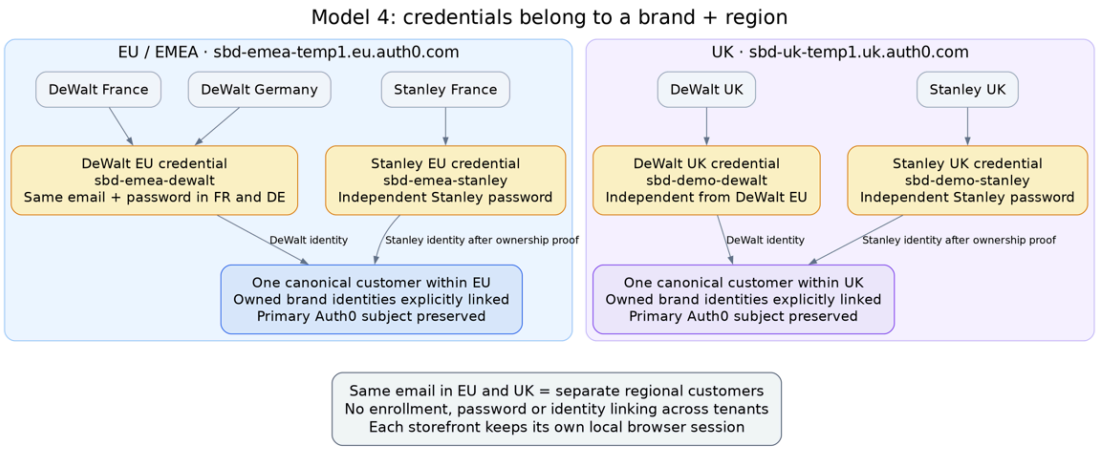
2. Current tenant and storefront topology

- **EU / EMEA:** `sbd-emea-temp1.eu.auth0.com`, hosted in the EU; DeWalt France, DeWalt Germany and Stanley France.
- **UK:** `sbd-uk-temp1.uk.auth0.com`, hosted in the UK; DeWalt UK and Stanley UK.

Live storefront	Regional tenant	Auth0 brand database connection	Credential scope
DeWalt France	EU / EMEA	`sbd-emea-dewalt`	DeWalt EU
DeWalt Germany	EU / EMEA	`sbd-emea-dewalt`	Same DeWalt EU credential
Stanley France	EU / EMEA	`sbd-emea-stanley`	Stanley EU
DeWalt UK	UK	`sbd-demo-dewalt`	DeWalt UK
Stanley UK	UK	`sbd-demo-stanley`	Stanley UK

There is one Auth0 application per storefront and one brand database connection per brand per tenant. DeWalt FR and DE have separate application clients but share the DeWalt EU connection. The Auth0 `email` and `google-oauth2` connections provide alternative identity proofs within each region.

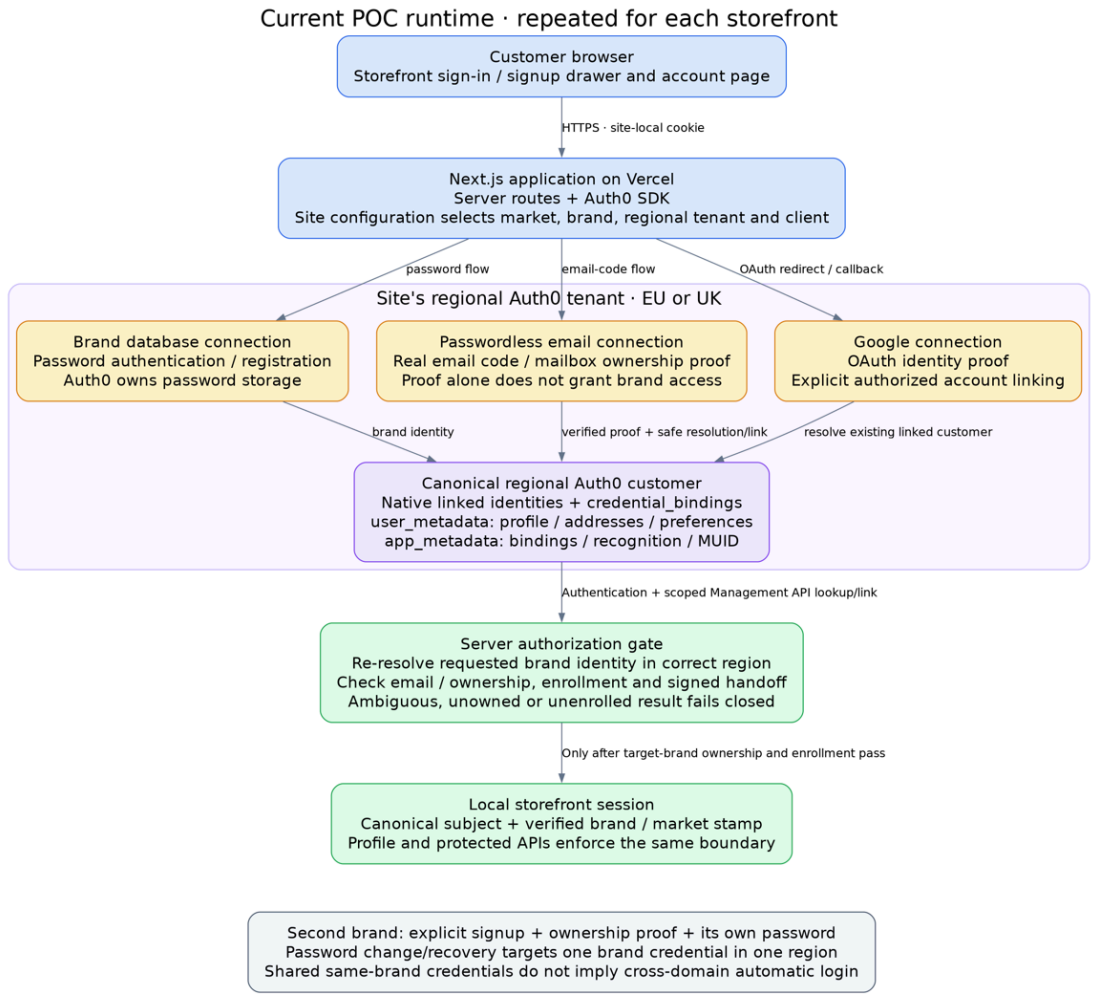
Brand and region identity diagram



Model 4 credential scopes: DeWalt FR/DE share the EU credential; Stanley and UK remain separate.

The two regional canonical customers are separate. Within either region, enrolling a second brand adds an owned brand identity to the existing customer; it does not turn the first brand's password into a password for both brands.

3. Current runtime architecture



Current deployed runtime: Auth0 identity proof, canonical regional customer, brand enrollment gate and local storefront session.

All five storefronts use the shared Next.js/React codebase, deployed as separate Vercel projects. Market and brand configuration select the regional tenant, storefront client and allowed brand connection. Password and email-code journeys run inside the storefront drawer; Google uses an OAuth redirect and callback.

Component	Actual responsibility
Storefront and server	Next.js 16.2.6 App Router, React 19, Node 24 and Auth0 Next.js SDK 4.26.0. Server routes handle registration, authentication and account operations.
Regional Auth0 client	Each storefront uses its own client/callback settings and an encrypted local `__session` cookie.
Scoped Management API	Server-side lookup, metadata updates and owned identity linking. Passwords remain managed by Auth0 database connections.
Target-brand password verifier	Account-page changes verify the current password with the existing client for the target brand and region. Ordinary storefront clients retain their own brand connection boundary.
Authorization gate	The proxy, profile and protected APIs require the requested brand identity and a verified brand/market session stamp. Unbound Google or email identities do not grant normal account access.
Auth0 post-login Action	Site recognition and SBD identity claims, including the existing MUID or canonical Auth0 subject fallback.

4. Identity and profile data

Location	Current data / meaning
Auth0 native `identities`	Owned brand database identities and explicitly linked email/Google identities on the canonical regional user.
Auth0 `user_metadata`	Profile, addresses and preferences, written through the account routes using the allowed metadata schema.
Auth0 `app_metadata`	Application-managed fields including `credential_bindings`, `muid`, `home_region`, `sbd_sites`, `login_alias_emails` and `sbd_passport`.
Credential binding	References a brand identity and its connection/credential scope. It does not contain the customer's password.
MUID / customer scope	The Action uses stored `app_metadata.muid` when present, otherwise the canonical Auth0 `user_id`. The POC has no global identity mapping or cross-tenant linking based on matching email.

The Auth0 database connections hold credentials; they are not separate customer-preference tables. The canonical user metadata holds the POC profile.

Optional code, inactive on the five storefronts: a Neon consent audit integration requires `DATABASE_URL`; an erasure webhook requires `SBD_ERASURE_WEBHOOK_URL`. Neither variable was present in the five projects' environment inventories on `Oct 2, 2026`. These are not active components in the runtime diagram.

5. Authentication, enrollment and recovery

Journey	Current implementation / expected result
First brand signup	Create the target brand database identity. Send the real Auth0 verification email; pending verification has limited access and no brand-password controls.

Same brand in another market	Use the existing brand/region credential. DeWalt FR and DE resolve to the same canonical EU account without a second DeWalt password.
Second-brand enrollment	Explicitly sign up for the target brand and choose its password. Prove ownership of the existing regional account before creating/linking the brand credential. Matching email alone never performs implicit linking.
Password sign-in	The server uses Auth0's password-realm grant against the allowed target brand connection. A different brand's or region's password does not authenticate this credential.
Email-code sign-in	Both tenants use the passwordless `email` connection as mailbox proof because brand database OTP is unavailable in these POC tenants. After verifying the actual code, the server re-resolves an already enrolled target-brand canonical account before issuing a session.
Mailbox proof safeguards	Signed purpose, email, brand, expiry and pre-send identity provenance protect the handoff. Existing foreign/unowned passwordless identities are not deleted or silently claimed. An unenrolled brand receives no access; the UI uses neutral delivery wording.
Google	An explicitly linked Google identity returns to the original regional customer. Requested brand enrollment remains required. A Google-only/unbound identity does not receive a full profile or normal protected API session.
Password change / recovery	Resolve and update the specific brand credential in the current tenant. DeWalt EU changes apply to both FR and DE. Stanley and UK credentials remain independent. Recovery does not itself create a signed-in session.

Session enforcement: `sbd_brand_verified` records the verified brand and market; the server checks it along with brand identity ownership. Failed, ambiguous, pending or unenrolled resolution fails closed instead of falling back to a shared identity.

6. Current UX and password policy

- Signup, sign-in and recovery identify the current brand/region and explain when another brand or region needs separate registration.
- The account page shows password actions for owned brand credentials. During the POC it can demonstrate either brand's password change from either brand's storefront, with target-brand current-password verification.
- The brand-password section carries the POC-only note: “This section is shown in the POC so we can test separate brand passwords.” This demo control is not a finalized production account-management design.
- **All five demos, EU and UK:** at least 8 characters, one lowercase letter, one uppercase letter and one special character. **Numbers are optional.** Longer passwords and additional characters are accepted within Auth0's existing 72-byte UTF-8 limit. There are no additional dictionary or email/name-content requirements. Passwords are not trimmed. The same rules apply to signup, second-brand enrollment, ownership proof, recovery and account password changes in the UI, server and all four active brand database connections. Existing credentials continue to work at sign-in.

7. Retired models and migration state

Earlier option	Current state
Models 1 and 2: shared password	Shared-password login, legacy/grandfather authorization and runtime shared-connection fallback removed from the active Model 4 flow.
Model 3: per-email passwords	Disabled and hidden. `NEXT_PUBLIC_UK_PER_EMAIL_ACCOUNTS` is off; gated per-email endpoints return 404 on all five sites. Source files

	retained behind the flag are not an active demo path.
Model 4: per-brand / per-region	The sole active model on EU and UK storefronts. Legacy/shared/orphan POC records were pruned while valid Model 4 customers were preserved.

8. Verification and shared-session demo

Release gate met: on `Oct 2, 2026`, three consecutive complete browser passes on the same live main release, with fresh customers in each round and the same 28 phases passing each time. All five production aliases were READY on the same main release before and after every pass. Exact merged-main automated verification passed: 784/784 tests, type check and production build.

Across the three passes, successful new-password journeys included 48 passwords with exactly eight characters and no digits, and six longer passwords containing spaces and the email prefix. The UI refused 216 invalid-password attempts and the live APIs refused 336 with HTTP 400. Each set separately checked seven characters, missing lowercase, missing uppercase and missing special character. Signup, second-brand enrollment, ownership proof, recovery and account password changes were covered. Invalid ownership-proof passwords were submitted with the real current email code; the same code still completed valid enrollment afterwards. Existing customer passwords also continued working.

- Real signup, verification and resend; pending access; both EU brand-enrollment orders and UK enrollment.
- DeWalt FR ↔ DE credential reuse, separate Stanley credentials, and separate same-email EU/UK canonical customers.
- Positive and negative passwords; actual email-code delivery, wrong-code refusal and resend on all five sites; unenrolled-brand refusal.
- Recovery on all five sites and six account-page password changes, including both cross-brand directions; old/new password and isolation checks.
- Linked Google recognition on the three EU sites and refusal of unbound Google on both UK sites; Model 3 hidden UI/disabled routes; truthful initial profile and POC copy.

Earlier Model 4 verification evidence from October 1, 2026 is recorded on CIAM-11 (comment 523942), CIAM-12 (comment 523943) and CIAM-13 (comment 523944). CIAM-12 was verified for the approved Model 4 path; its historical per-email option remains disabled.

Shared demo order: register and verify DeWalt FR → sign in to DeWalt DE with the same credential → show Stanley refusal before enrollment → explicitly enroll Stanley and prove ownership → show independent Stanley password and same regional profile → reset/change DeWalt and confirm FR/DE propagation with Stanley unchanged → register the same email in UK and show regional isolation → test email-code and linked Google access without bypassing brand enrollment.

Verification limit: live UK email-code settings were independently confirmed as six digits / 180 seconds; the EU/UK setup specifies the same configuration. Expired, tampered and reused handoffs are covered by automated tests. The Auth0 verification-email link lifetime remains tenant-template controlled and was not independently confirmed or elapsed-tested in the browser.

9. Relationship to the broader architecture proposal

The Okta/Auth0 Region Architecture Proposal remains the broader global-region and Universal Login proposal. This page documents the current two-region POC, its custom storefront authentication drawer and its selected credential model. Global rollout, AIC/Okta coexistence, data synchronization and production migration planning remain separate workstreams.

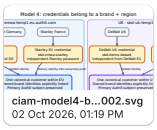
UUP, GPI, Polaris and Treasure Data are not shown as implemented POC integrations. The downstream system list and journey screens are proposals; this release does not establish production downstream synchronization or automatic cross-domain SSO.

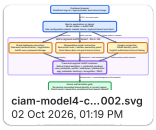
References

- CIAM/Auth0: Four Identity Models for Stakeholder Decision
- Okta Auth 0 Region Architecture Proposal
- https://github.com/Customer-Engagement-Digital-Technology/sbd-brand-region-demo Connect your Github account

Diagram downloads

PNG diagrams are embedded above. Vector copies are attached for reuse in architecture discussions.


ciam-model4-b...002.svg
02 Oct 2026, 01:19 PM


ciam-model4-c...002.svg
02 Oct 2026, 01:19 PM